

ARA - Access Risk Analysis

VIRSA 4.0 ----- > Compliance Calibrator (CC)

GRC AC 5.1, 5.2, 5.3 ----- > Risk Analysis & Remediation (RAR)

GRC AC 10, 10.1,12 ----- > Access Risk Analysis (ARA)

What is difference between ARA (AC) and RM (GRC)?

ARA - **Component of AC** which deals with Risks related to SAP
Access/Authorizations

RM - **Component of GRC**, which deals with over all risks in Org

- Strategic Risk.
- Compliance Risk.
- Operational Risk Ex,, COVID
- Financial Risk.
- Reputational Risk.

Risk: Futuristic - Something which impacts your business – Financial/
Reputational/Operational/Natural

- **Probability** – Chances of its occurrence – Depends on **Experience**
or knowledge

Ex, **Betting** – 50% probability of Losing

- **Risk is not universal** – Risk depends on local factors- It varies from
company to company or location.

ARA deals with only **Access/Authorization** related risks.

Ex, Reliance Power

Maharashtra – 5th of every month

MP – 10th of every month

Gujarat – 15th of every month – Supply power to 10K industries

Payment Receiving (T1) + **Payment Adjustments (T2)**

SOD risk – T1 + T2 because of not segregating the duties which are conflicting in nature, this risk occurs.

Terminology:

Action ----- > T-code

Permission ----- > Auth Values (Auth Objects, Auth Fields and Values)

- ❖ Access Risk – Identification – **Risk Analysis & Simulation**
- ❖ Access Risk – Remove or Avoid – **Risk Remediation**
- ❖ Access Risk – Reduce its impact/Control – **Risk Mitigation**

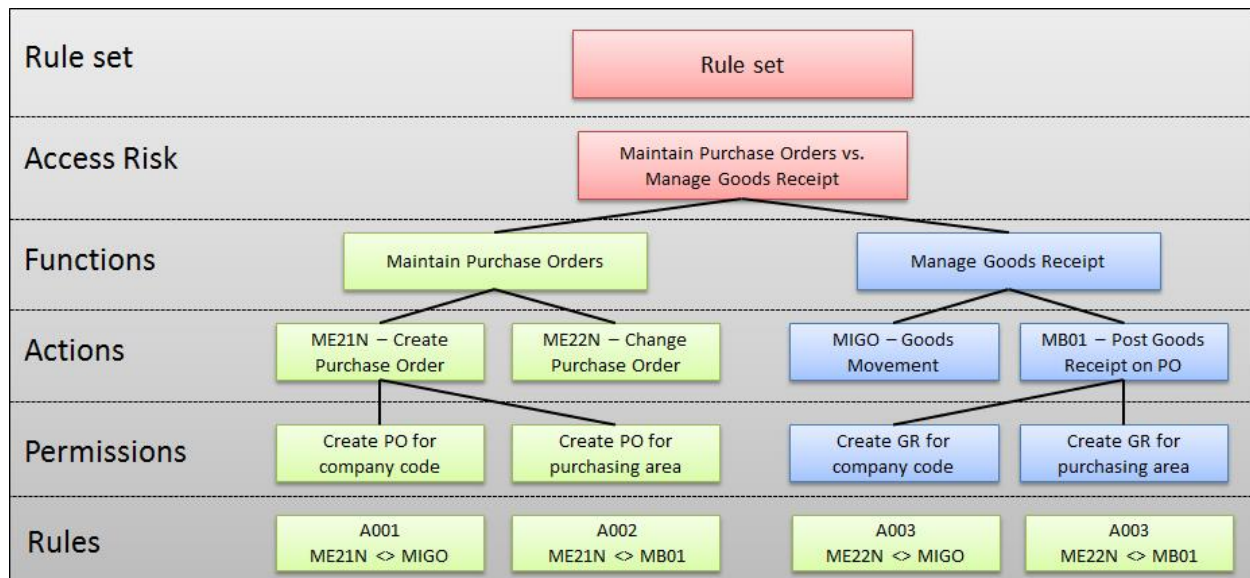
To identify a Risk – **Experience/Knowledge** – Self or Others

Global Rule Set – It is database of **Access Risks**, faced by reputed companies in the last 100 years and risks have been Organized process wise (Finance, HR, Sales...)

```

graph LR
    A([Your Business]) -- "Risks can be identified in your business" --> B[Global Rule Set]
  
```

- 1) **SOD Risk** – Combination of **conflicting** functions –
Action Level = SU01+SCC4, SCC4+STMS
 , ME21N+MB01, FB01+FBVO
Permission Level = Auth Values of SU01 + Auth Values of SCC4
- 2) **Critical Action Risk** – SCC5, SE38, SPRO
- 3) **Critical Permission Risk** – SCC5 : S_TABU_DIS with Activity 01 or 02, SE38: S DEVELOP With Activity:01 or 02



Why do we go for Custom Rule set?

1) To define new Risks which are not part of GLOBAL

Ex,, Custom T-codes

2) All Risks in GLOBAL may not be applicable to our Business.

Steps to create custom rule set:

1. Rule set Creation:

NWBC ----- > SET UP ----- > Access Rule Maintenance ----- > Rule Set

Create a Custom Rule set as per your Client Requirement - Name

2. Business Processes: (Departments)

SPRO ----- > GRC ----- > Access Control ----- > Maintain Business process and Sub processes

3. Function Creation:

NWBC ----- > SET UP ----- > Access Rule Maintenance ----- > Functions

ECC - ECCCLNT100

BW - BWCLNT100

HR - HRCLNT100

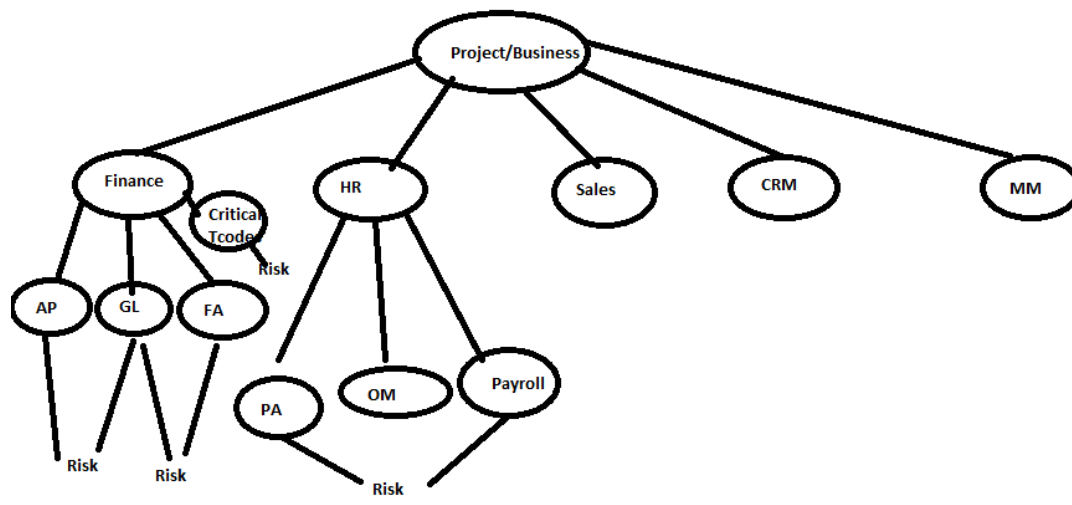
ARA: Risk Analysis Function Creation

BMW_GROUP

ECCCLNT100

BWCLNT100

HRCLNT100



SOD Risk at Action Level:

To create a SOD risk, we need Business process, 2 functions and T-codes/Auth data in Functions

Ex, Business Process ----- > **BASIS** (GE_BASIS)

Path: SPRO --- > GRC ---- > AC ----- > Maintain BPs and Sub Processes

Functions ----- > **GE_SEC**:SU01, PFCG, **GE_CLAD**: SCC4, SCC5, SCCL, SCC9

SOD Risk: **GE_SOD1** = **GE_CLAD** + **GE_SEC**

EX, SU01 + SCC4 combination is a Risk

SU01 = User Maintain

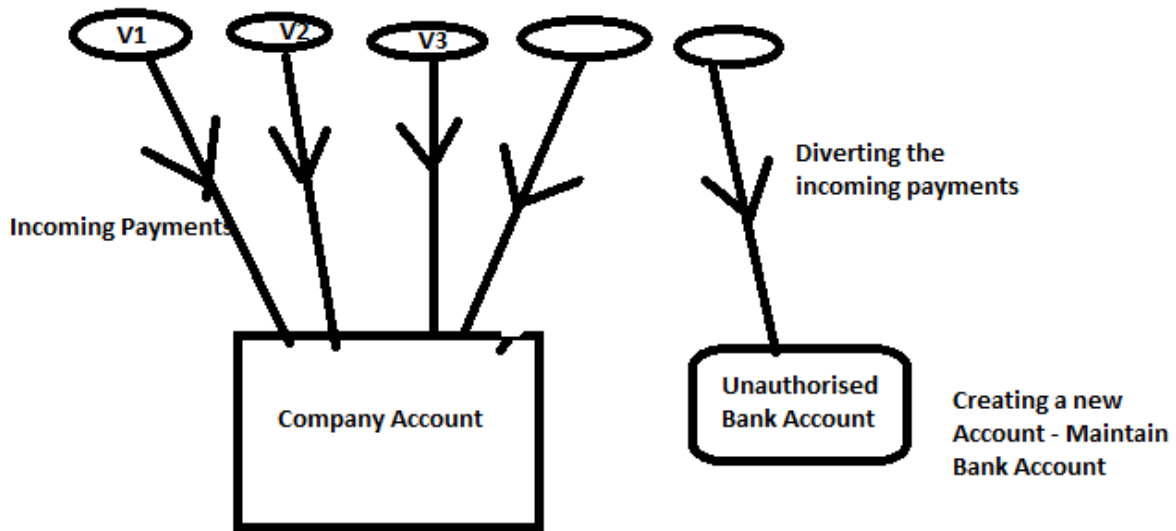
SCC4 = Client Creation

Once the Risk ID is created, we need to generate the rules

Rules = Risk causing combinations Ex,, SU01+SCC4

SOD Risk example:

Finance Risk: **F017**---- > Maintain bank account and divert incoming payments



SOD Risk at Permission Level:

- SU01+SCC4 = Display Access of SU01 = S_USER_GRP
With Activity: 03 and CLASS: *

SU01 ----> S_USER_GRP with Activity: 01/02/05/06/22

SCC4 -----> S_TABU_DIS with Auth Group: SS, Activity: 01/02

User 1

SU01 -----> S_USER_GRP

Actvt: 01

SCC5 -----> S_TABU_CLI

Clientmaint:

- **STMS Full+ SCC4 Full** ---> combination is risk causing

SU01:

- S_TCODE with TCD: STMS

SCC4:

- S_TCODE with TCD: SCC4
- S_TABU_DIS with Activity: 01 or 02 & Auth Group: SS

Example:

SU01+SCC4

Can create a user + Client Settings = Risk

SU01 Display + SCC4 Display = Not Risk

SU01 Display + SCC4 Maintain = Not Risk

SU01 Maintain + SCC4 Display = Not risk

SU01 Maintain + SCC4 Maintain = Risk

SU01

S_USER_GRP (user Creation)

Activity: 01 or 02 or 06 or 22 or 05

S_USER_AGR

Activity: 01 or 02 or 06

S_USER_AGR (Role Assignment)

S_USER_PRO (Profile Assignment)

SCC4

S_TABU_DIS

Activity: 01 or 02

Auth Group: SS

User1 = SU01 Display + PFCG Maintain

SOD Action level = SU01+PFCG = Risk

SOD Permission Level = SU01 Display + PFCG Maintain = Not risk

USER1

SU01

S_USER_GRP

Activity: 01

User2:

S_USER_GRP

Activity: 02

Critical Action Risk:

To create a Critical Action Risk, we need one function which contains all critical **t-codes** in that Business process.

PG_CAF: SPAM, SPRO, SU25, SCC5, SU24

PG_RISK2 ---- > PG_CAF

Critical Permission Risk:

To create Critical Permission Risk, we need one function which contains all critical **Auth Values** – Auth Objects, Auth Fields and Values

(No T-codes)

PG_CPF:

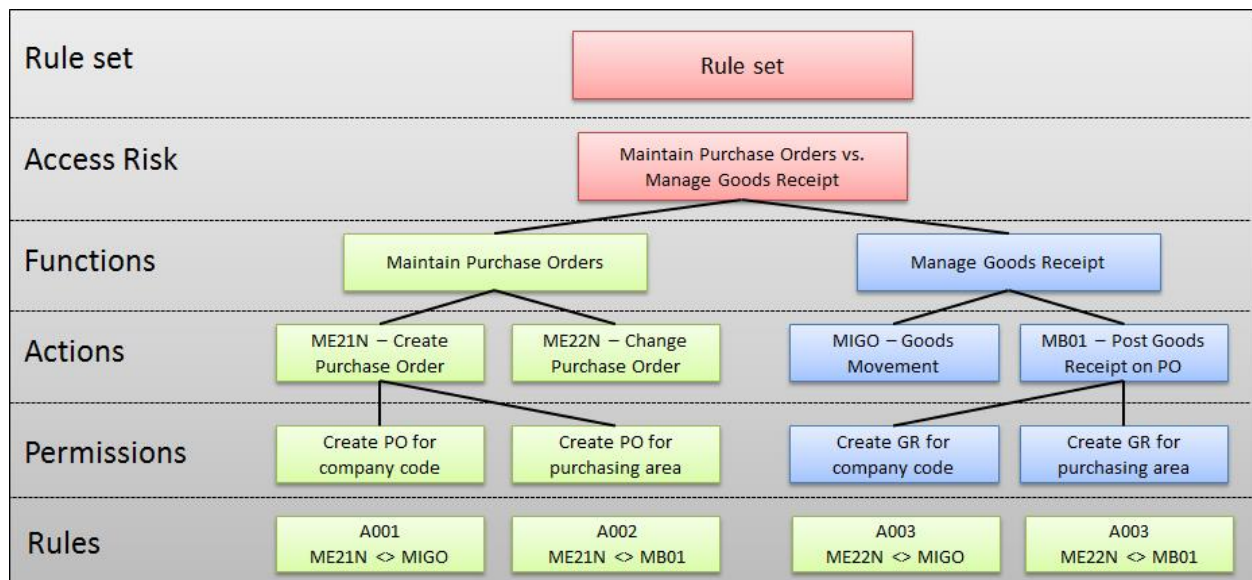
SCC5: S_TABU_CLI with CLIENTMAINT: X

SE38: S_DEVELOP with ACTVT: 01 or 02

CAT_RK3 ----- > CAT_CPF

Action = T-code

Permission = Auth Values



Risk Levels: (based on impact done to business)

- 1) Low
- 2) Medium
- 3) High
- 4) Critical

Risk Analysis path:

NWBC ----- > Access Management ----- > Access Risk Analysis

Risk Analysis Report Formats:

- **Detail** – gives you max info
- **Summary**
- **Management Summary**
- **Executive Summary**

Risk Analysis Levels:

- 1) User Level
- 2) Role Level
- 3) HR Objects Level – Position/Org Unit/Job
- 4) Profile Level

Which is preferable: User Level or Role Level?

Role Level Risk Analysis ----> to detect Critical Action/Permission Risk

Role1: SU01 ----- > No Risk

Role2: SCC4 ----> No Risk

Role3: SPRO ---- > Critical Action RISK/Permission

User Level Risk Analysis ----- > to detect SOD risks

User1 --- > SU01+SCC4 ---- > SOD Risk

Role1

Role2

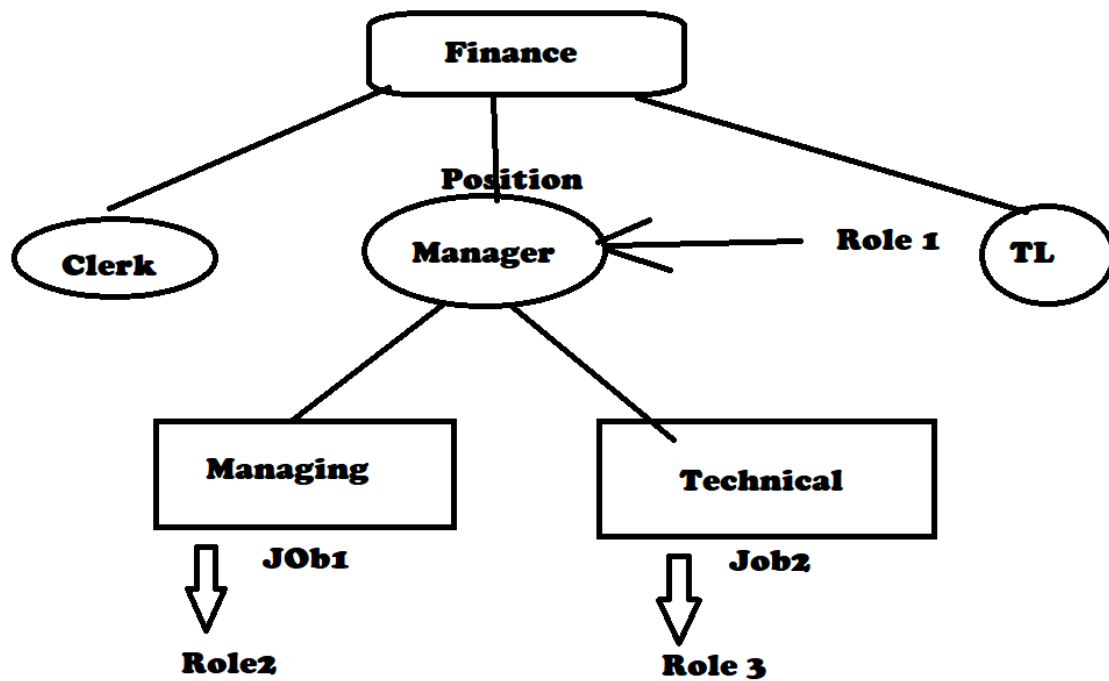
Role level

Critical Action Risk

Critical Permission Risk

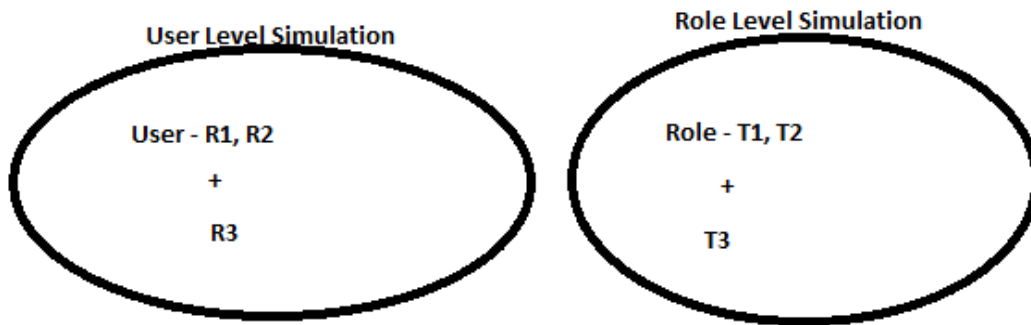
User Level

SOD Risk



Risk Simulation:

- User Level = Whenever User asks for extra access
- Role Level = Whenever role has to be modified (adding/removing t-codes or authorization from the roles)



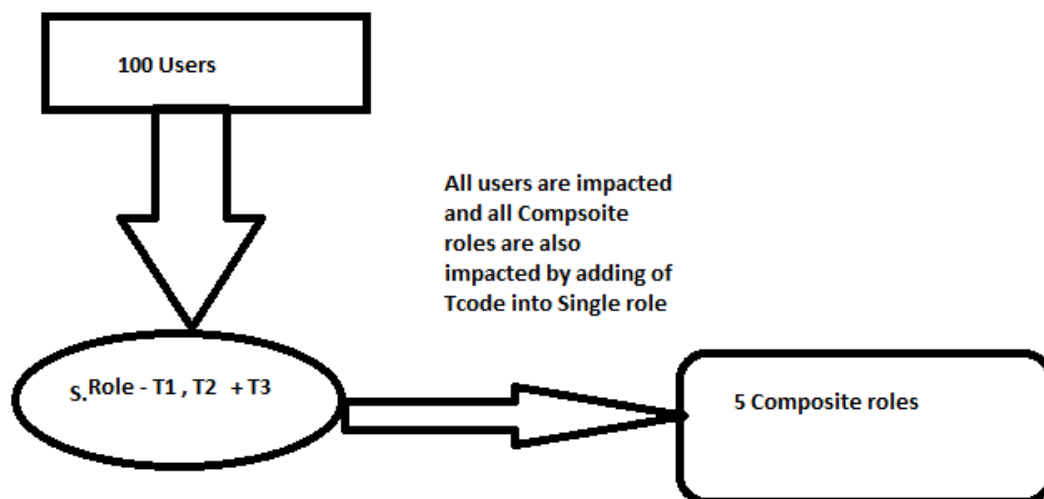
Risks from Simulation Only? ----- > To check the risks coming due to **adding** of a t-code/role/profile to user (It does not show already existing risks)

Exclude Values? ----- > To check left over risks, when T-code/role/profile is **removed** from User. (Ensure that T-code/Role should be assigned to User)

Simulation can be done in 2 levels

- User level
- Role level

Role Level Simulation:



Defining Risk Owner:

Risk Owner:

Risk Owners are assigned to risks and are commonly responsible for approving changes to risk definitions and violations of the risk. Risk Owners may also receive conflicting and critical action alerts.

Steps to define Risk Owner:

- 1) Ensure the user id is present in the **GRC system** with the necessary Authorizations.
- 2) Declare that user id as **Risk Owner** in the below path
NWBC ---- > SET UP ----- > Access Owners ---- > Access Control Owners
- 3) Open the Risk ID and define the above id as Risk owner for that particular Risk ID

Risk Analysis Report is sent to **Risk Owner** in 2 ways

- Manual – Download the report and send mail
- Automated – ARM Concept – Access request Work flow

1st Priority: To Remediate Risk (Removal of a Risk)

2nd Priority: To Mitigate Risk (Risk Reduction/ Control Risk)

Risk Remediation:

It means removing risk by removing access

How to remove access to user?

1) Role modification - Remove the risk causing T-code/Auth Values from the role that is assigned to user - **Multiple Users**

2) Role removal from the user - Unassign the role - **SINGLE USER**

USER1

ROLE 1 ---- > SCC5, SCC4, SCCL, SCC9

Solutions:

1. Removing the role to user:

User is left with no access

2. Remove Tcode from the Role1

Role1 is assigned to 10 other users

3. Search/Create a role without SCC5, copy of Role1

Assign this to USER1

NBA_USER1 has risk

When you run risk analysis to all users in System

GE_RSK1 is available to 100 users

GE_RSK1 is caused due to Client Admin and SEC Admin

100 users = 20 BASIS Team + 80 Non BASIS Team

There is only one role assigned to 100 users.

User Admin role is assigned to 100 Users (BMW_USER1)

SU01+SCC4

SU01+SCCL

Su01 ---- > USER Admin Role

SCC4, SCCL ---- > Client Admin Role

BMW_USER1 belongs to which Team?

1) Security ----- > Remove Client Admin Access

2) BASIS ----- > Remove USER Admin Access

3) Security + BASIS ----->

Removing of User Admin Access:

#####

1) Remove SU01 from User Admin Role ??? Role Modification ??
Approvals ???

2) Create Another ROle ---- > PROCESS ?? APPROVAL ???

3) Remove User Admin Role ----> Other tcodes are also lost, Search for
role

which does not contain Su01 and assign that Role to the user.

Risk Mitigation:

Reducing the probability of its occurrence or impact of the risk

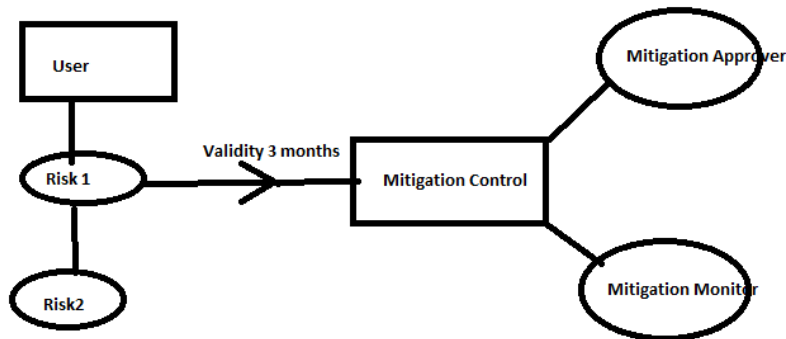
How? By monitoring mechanism

Mitigation Controls

- Specific to Business Process (HR, FIN, SD, MM)
- Specific to **Organization Hierarchy** (Country/Region Specific)
- Ex,, **GDPR** – General Data Protection Regulation - EUROPE

Mitigation Approver – Responsible for approvals to assign Mitigation Controls for Users and also approving changes to Mitigation Control Definition

Mitigation Monitor – Responsible for monitoring the mitigated users who have risks in the form of Alerts and Notification.



MIT1-----> RISK1, RISK2

MIT2-----> RISK1, RISK3

Replace BHP_MIT_APP1 with BHP_MIT_APP2 as Mitigation Approver

BASIS	Risks	Mitigation Control	Approver	Monitor
	BS_RISK1	BS_MIT1	A1	M1
	BS_RISK2	BS_MIT1		
DBA	BS_RISK3			
	BS_RISK4	BS_MIT1		
	BS_RISK5	BS_MIT1		
	BS_RISK6	BS_MIT2	A2	M2
	BS_RISK7			
SYSADM	BS_RISK8			
	BS_RISK9			
	BS_RISK10			
	BS_RISK11	BS_MIT3	A3	M3
	BS_RISK12			
OSA	BS_RISK13			

	BS_RISK14			
	BS_RISK15			
	BS_RISK16	BS_MIT4	A4	M4
SYSMON	BS_RISK17			
	BS_RISK18			
	BS_RISK19			
	BS_RISK20			

HR	Risks	Mitigation Control	Approver	Monitor
PA	HR_RISK1	HR_MIT1	A5	M5
PA	HR_RISK2			
PA	HR_RISK3			
PA	HR_RISK4			
PA	HR_RISK5			
OM	HR_RISK6	HR_MIT2	A6	M6
OM	HR_RISK7			
Payroll	HR_RISK8	HR_MIT3	A7	M7
Payroll	HR_RISK9			
Payroll	HR_RISK10			

Mitigation Control:

Steps

- 1) Ensure user ids exist in **GRC system** for **Mitigation Approver** and **Monitors**

Mitigation Approver Role: SAP_GRAC_CONTROL_APPROVER

Mitigation Monitor Role: SAP_GRAC_CONTROL_MONITOR

SAP_GRAC_ACCESS_REQUESTER
SAP_GRAC_CONTROL_MONITOR
SAP_GRAC_DISPLAY_ALL
SAP_GRAC_END_USER
SAP_GRAC_NWBC

- 2) Define/Declare them in GRC system as **Mitigation Approver** and **Monitor** in **NWBC ----- > Set up ----- > Access Control Owners**

- 3) Create **Root Org** in **SPRO ----- > GRC ----- > Shared Master Data**
(Mitigation Controls are specific to Org units) and related Child org if required under **NWBC ----- > SET UP ----- > Org**
- 4) Define **OWNERS** for the ORG
- 5) Create Mitigation Control **NWBC ----- > SET UP ----- > Mitigation Controls**

BASIS team -- 5 BASIS Risks BASIS_MIT1 A1M1
5 BASIS Risks BASIS_MIT2 A2 M2

Finance Team --- 30 Finance Risks FIN_MIT1 A2 M2 AP
FIN_MIT2 A4 M4 FA
FIN_MIT3 A5 M5 GL
Sales Team ---- Sales Risks SALES_MIT1 A3 M3

Note: Every Risk ID should be part of some Mitigation Control, else it cannot be mitigated.

Mitigation Control Validity is controlled by a parameter under the below path

SPRO----- > GRC ----- > Access Control ----- > Maintain Configuration Settings

Parameter ID: 1011 ---- > Default Expiration time for Mitigation Control Assignment
Default Validity: 1 Year (365 days)

Process of mitigating risks:

- 1) User has a risk
- 2) Risk report is sent to **Risk owner** and decides to Mitigate, it has to be approved by **Mitigation Approver**
- 3) If they decide to mitigate, we need to link the risk id with appropriate mitigation control
- 4) If Mitigation control is not available for that particular risk, its Security/GRC team duty to create a Mitigation Control.
- 5) Ensure that every risk id is associated with some Mitigation Control otherwise that risk cannot be Mitigated

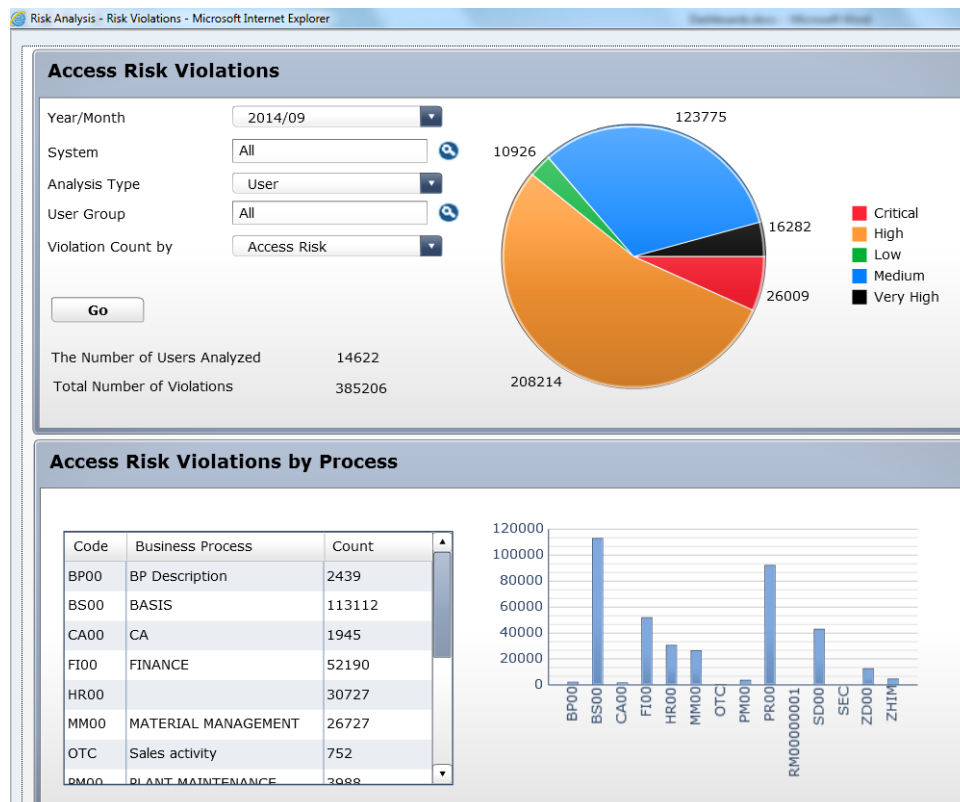
Batch Risk Analysis:

SPRO ----- > GRC ----- > AC ----- > Access Risk Analysis ---- > Batch Risk Analysis ----- > Execute Batch Risk Analysis

It is performing/running risk analysis for all users & roles in the system and updates the table **GRACMGRISKD** & dashboards under **Reports and Analytics Tab** under **NWBC**

Purpose:

- 1) Risk Analysis Dashboards
- 2) Offline Risk Analysis
- 3) Risk Monitoring Job



What is difference between **Offline Risk Analysis** and **Online Risk Analysis**?

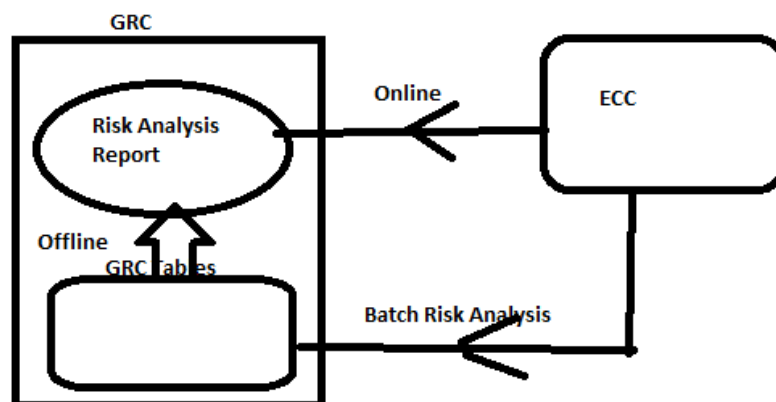
Online Risk Analysis:

- GRC pulls the data from backend ECC and run risk analysis
- Accurate Data and updated data
- System performance – Late response
- If RFC error is there, this fails

Offline Risk Analysis:

- GRC pulls the risk analysis data stored in Local GRC Tables- **GRACMGRISKD** (Dashboards) – These tables get updated by **BATCH RISK ANALYSIS** job.
- It may not be Accurate data and not updated
- System performance – Fast response
- If there is RFC error, still we get the Risk Analysis Report.

Parameter ID: 1027 controls the enabling the Offline Risk Analysis



What do you mean by False Positives?

There is no risk ideally, but GRC system shows as a Risk as per the Rule set data defined.

SU53 is Risk ----> RISK

User 1 has SU53 ---> RISK

Example1: 2 conflicting functions have same T-code

AP02 --- > FB01

GL01 ----> FB01

Risk ID: F028 (SOD RISK) ---- > AP02+GL01

User: FB01

Risk Analysis

SOD RISK = F028 = FB01 (AP02) + FB01 (GL01)

Example2: Finance SOD Risk

Action Level Rule: Create Invoice (**FB01**) & Approve Invoice (**FBV0**)

Permission Level Rule: FB01 ---- >AO1 with Activity: 01

FBV0 ----- > AO2 with Activity: Approve

User

Role1: FB01 --- > AO1 with Activity 01, Plant: 100 (INDIA)

Role2: FBV0 ---- > AO2 with Activity: Approve, Plant: 200 (JAPAN)

How to avoid FALSE POSITIVES?

1) Org rules need to be defined

Org Rule: AO1 with Act: 01 & Plant: 100

AO2 with Act: 01 & Plant: 200

Note: System takes more time when running risk analysis as it has to consider extra rules like Org Rules, Supplementary Rules other than Action rules, permission rules, etc.....

2) Create Dummy Mitigation Control and Mitigate the Risk

SOD Rules/ Rule set Upload/Download and Transports:

SPRO ---- > GRC ---- > Access Control ----- > Risk Analysis --- > SOD Rules

Purpose:

1) To move data from Dev to QA & PROD

Transports:

What type of Transport Request is needed to move Rule set?

Ans: Customizing TR

After importing into target system (Dev --- > qua --- > Prod), generate the rules for all Risk Ids.

2) To modify the rule set data - **Mass Changes**

Upload Rules:

GRAC_UPLOAD_RULES

Download Rules:

GRAC_DOWNLOAD_RULES

Creating new Risks IDs:

What all files need to be updated?

- Function
- Function Actions
- Function Permissions

- Function Business Process
- Risk
- Risk Description
- Risk Rule Set relationship

Create a new Business Process:

- Business Process

Create a new Function:

- Function
- Function Business Process
- Function Actions
- Function Permissions

When do you do Risk Analysis?

User Administration – User Creation, Modification

Role Administration – Role creation, modification

Maintaining Rule set – BP, Functions and Risk ids

Mitigation Control Maintenance – Creation and Modification

Maintaining Approvers – Risk Owner, Mitigation Approver/Monitor

Parameters Config – Risk Analysis, Mitigation